

■ Informe Integral de Auditoría Multidisciplinaria y Plan de Optimización — Ecosistema TrueKeat

■ Resumen Ejecutivo

No obstante, se han detectado **hallazgos críticos de seguridad, privacidad y consistencia** que deben subsanarse para garantizar un despliegue seguro y escalable en producción:

1. Smart Contracts & Tokenomics	■ CRÍTICO	Secuestro en `disputeOperation`, falta de	
		`ERC20Permit` en BRLT y SafeERC20.	
2. Backend, DB & Criptografía	■ CRÍTICO	Fuga de PII en `/api/identity` y riesgo de	
		drenaje de gas en relay EIP-712.	
3. Requisitos & Stakeholders	■ ALTO	PII en claro en `UserRegistry.sol` (GDPR),	
		falta de transportistas y timeout en disputas.	
4. Frontend, PWA & UX/UI	■ MEDIO	Colores legacy en PWA manifest, contraste de	
		oro sobre blanco y sanitización de errores Web3.	
+-----+-----+-----+-----+			

1. Auditoría de Smart Contracts y Tokenomics (`sc/src/`)

■ Hallazgos Críticos:

1. Secuestro de Garantías en Disputas (`Escrow.sol` L406-448):

- ***Problema:*** La función `disputeOperation(id)` permite que cualquier tercero no participante llame a la función y se convierta en `user2`. Si el árbitro falla contra `user1`, el atacante recibe el 100% de `TokenA` sin haber depositado nada.
- ***Solución:*** Restringir `disputeOperation` exclusivamente a `msg.sender == user1 || msg.sender == user2`.

2. Incompatibilidad de Meta-Transacciones con BRLT (`BRLT.sol`):

- ***Problema:*** `Escrow.sol` exige `IERC20Permit.permit(...)` en meta-transacciones sin gas, pero `BRLT.sol` solo hereda `ERC20` estándar.
- ***Solución:*** Hacer que `BRLT.sol` herede `ERC20Permit("BorloTokens")`.

3. Falta de `SafeERC20` y Patrón CEI (Checks-Effects-Interactions):

- ***Problema:*** Se usan transferencias crudas antes de actualizar el estado del contrato (`status = Cancelled`), exponiendo a reentrancy en tokens con hooks.
- ***Solución:*** Implementar `using SafeERC20 for IERC20` y actualizar siempre el estado antes de transferir.

4. Admisión de Socios sin Quórum en Gobernanza (`Governance.sol`):

- ***Problema:*** `resolveSocioApplication` no valida `minQuorum` y acepta cualquier token de depósito no verificado.
- ***Solución:*** Exigir lista blanca de tokens de depósito (`allowedDepositTokens`) y quórum mínimo obligatorio.

2. Auditoría de Backend, Base de Datos y Criptografía

■ Hallazgos Críticos:

1. Fuga de Datos Sensibles en `/api/identity/[address]`:

- ***Problema:*** El parámetro `requester` se pasa como query param sin firma criptográfica ni sesión, permitiendo que cualquiera consulte emails, teléfonos y secretos 2FA descifrados de cualquier cuenta.
- ***Solución:*** Implementar **Sign-In with Ethereum (SIWE)** y validar la firma ECDSA del llamador antes de entregar PII.

2. Vulnerabilidad de Drenaje de Gas en Relay (`/api/relay`):

- ***Problema:*** El relay no simula previamente la transacción con `staticCall`, permitiendo a atacantes forzar transacciones fallidas que consumen el saldo de gas de la tesorería.
- ***Solución:*** Pre-ejecutar `staticCall`, aplicar rate limiting por IP/Wallet y alertar si el saldo del relay baja de 0.05 ETH.

3. Idempotencia y Resiliencia del Indexador (`indexer.mjs`):

- ***Problema:** El indexador no almacena el bloque de sincronización persistente (`last\_synced\_block`) y re-escanea desde el bloque 0 en cada reinicio, duplicando notificaciones históricas.
- ***Solución:** Crear tabla `indexer\_state` y calcular IDs deterministas para notificaciones `sha256(txHash + logIndex)`.

4. Validación TOTP 2FA Real (`lib.js`):

- ***Problema:** La función `confirm2FA` solo validaba que el código fuera de 6 dígitos numéricos sin cotejar el algoritmo TOTP (RFC 6238).
- ***Solución:** Integrar `otplib` para validación temporal con clave Base32.

3. Auditoría de Requisitos, Stakeholders y Negocio

```
graph TD
    subgraph Stakeholders_Actuales["Stakeholders Validados"]
        S1[Socios Fundadores]
        S2[Socios Árbitros]
        S3[Empresas Comerciales]
        S4[Productores RWA]
        S5[Usuarios Particulares]
        S6[Operador de Relayer]
        S7[Tesorería Comunitaria]
    end

    subgraph Stakeholders_Faltantes["Nuevos Stakeholders Requeridos"]
        N1[■ Couriers y Transportistas]
        N2[■ Peritos y Certificadores de Calidad RWA]
        N3[■ Almacenes Generales de Depósito / Silos]
        N4[■ Delegado de Cumplimiento / Custodio DPO]
    end

    S3 <--> N1
    S4 <--> N2
    S4 <--> N3
    S5 <--> N1
```

■ Requisitos No Funcionales (RNF) y Privacidad:

1. Conflicto de Privacidad On-Chain (RGPD / Habeas Data):

- ***Problema:** `UserRegistry.sol` guarda emails, teléfonos y direcciones físicas en claro en la blockchain pública.
- ***Solución:** Almacenar únicamente hashes criptográficos `bytes32` on-chain y mantener los datos reales cifrados con AES-256-GCM en PostgreSQL.

2. SLA y Timeout en Disputas Arbitrales:

- ***Problema:** Una operación en disputa queda congelada indefinidamente si el árbitro no actúa.
- ***Solución:** Incorporar un timeout de 14 días (`DISPUTE\_RESOLUTION\_WINDOW`) tras el cual el creador puede solicitar el reembolso automático.

3. Estandarización de Marca y Nomenclatura:

- Unificar el nombre comercial en **TrueKeate** (con subtítulo de protocolo ***TrueKeat***), y el token comunitario como **BarloTokens (BRLT)**.

4. Auditoría de Frontend, Ergonomía Móvil y PWA

■ Mejoras UI/UX y Accesibilidad:

1. Unificación de la Landing Page:

- Conectar directamente `LandingPage.tsx` con el Sistema de Diseño 2.0 (Deep Navy `#1A2B4C`, Teal `#2A9D8F`, Gold `#D4AF37`) en la ruta raíz `.`.

2. PWA Manifest y Colores de Tema:

- Actualizar `manifest.ts` de los colores tierra legacy (`#2D2A26`) a la paleta oficial (`theme\_color: '#1A2B4C',`
`background\_color: '#F8F9FA'`).

3. Banner de Estado Offline PWA:

- Implementar `OfflineBanner.tsx` con detección en tiempo real para alertar al usuario en zonas con intermitencia de red.

4. Sanitización de Errores Web3 (`getFriendlyError`):

- Interceptar rechazos de firma de MetaMask (código `4001` / `ACTION\_REJECTED`) para mostrar mensajes claros en español en lugar de trazas crudas.

5. Cumplimiento WCAG 2.1 AA:

- Ajustar contraste del color oro sobre fondos claros y añadir atributos `aria-modal`, `role="dialog"` y soporte para cierre con tecla `Escape` en modales.

5. Plan de Acción y Hoja de Ruta Priorizada

timeline

title Hoja de Ruta de Optimización TrueKeate v2.0

Fase 1 (P0 - Seguridad Inmediata) : Parchear disputeOperation en Escrow : Permit EIP-2612 en BRLT : Autenticaci

Fase 2 (P1 - Robustecimiento) : Cursor persistente en Indexador : Protección contra Reorgs : Quórum en Gobernan

Fase 3 (P2 - Madurez de Negocio) : Hashes ZK en UserRegistry : Timeout SLA en Disputas : Rol de Transportista C

6. Conclusión

El ecosistema **TrueKeat / TrueKeate** posee un diseño conceptual y técnico de vanguardia. La ejecución del presente plan de optimización garantizará un estándar bancario de seguridad, pleno cumplimiento de privacidad de datos y una experiencia de usuario fluida y confiable en dispositivos móviles y de escritorio.